

Core Platform Framework

91 Gateway 매뉴얼

API 아키텍트 · Gateway 운영자 · 보안 담당자

문서 목적	외부 Client 와 내부 Service 사이의 Route·Target·인증·보안·Resilience·게시·부분 적용·LKG·Rollback 을 선택·설치·운영합니다.
Repository / Branch	freeangelsun/202412_01_CPF / master
기준 Source / 정보	Repository f6d7080c5a14b7dd7595093f9497470169e18d80 Product Source f0aa49f29cba3cfd6ae12b0ddd4e118d05fff16c 최상위 요구사항 cpf-docs/governance/CPF_FINAL_TARGET_REQUIREMENTS.md 문서 표준 cpf-docs/specification/CPF_DOCUMENTATION_STANDARD.md
문서 성격	완성 기준 사용자 문서. 제품이 완료된 상태에서 사용자가 설치·개발·운영·복구·검증 업무를 끝낼 수 있도록 정상 절차, 실패 판정, 복구, 확인 근거를 기술합니다.

읽는 방법 먼저 “빠른 찾기”에서 질문을 찾고, 상세 설명은 각 기능의 정보 절로 이동하십시오. 다른 매뉴얼은 같은 내용을 반복하지 않고 정보 절을 참조합니다.

빠른 찾기 - 질문에서 정보 절로

개발자가 묻는 질문	이 문서의 정보 위치	다른 문서 연결
Gateway 를 언제 써야 하나?	§2 선택 기준	외부 trust boundary/route/policy 가 필요할 때
어떻게 설치/기동?	§3~§4	DB/Port/TLS/Health/Fail-closed
Route 는 어떻게 설정?	§5	Server Group/Binding/Predicate/Rewrite
HMAC/Nonce/TLS 는?	§7	보안 체인
Timeout/Retry 는?	§8	설치 상한 + Route 정책
게시 후 일부 Instance 만 실패?	§10~§12	ACK/NACK/Partial Apply/LKG/Reconcile
ADM 어디서 보나?	§13	04 Gateway Route

완성 기준 이 문서는 제품 완료 상태에서 사용자가 수행할 최종 업무 계약을 기술합니다. 각 절은 선행조건 → 입력/설정 → 실행 → 정상 판정 → 실패/부분 실패 → 복구/대사 → Evidence 순서로 담으며, Source Trace 는 구현 위치를 제공합니다.

1. 제품 역할과 책임 경계

Gateway 는 외부 진입의 trust boundary 와 Route/Target/Load Balance/Resilience/Attempt Ledger 를 담당합니다. 내부 서비스끼리의 모든 호출을 Gateway 로 강제 우회시키는 제품이 아닙니다.

2. 선택 기준 - 언제 쓰고 언제 쓰지 않는가

상황	판단
외부/제휴 Client API 공개, 인증/라우팅/Rate limit/Target 통제 필요	Gateway 선택
내부 동일 JVM 호출	Gateway 경유 금지; Local 계약 사용
내부 Microservice 직접 호출	Service Registry/Remote 계약이 기본; 외부 trust boundary 가 아니면 Gateway 필수 아님
다수 Instance 에 Route 정책 게시/승인/LKG 필요	Gateway + ADM Control Plane 적합
단순 Reverse Proxy 만 필요	CPF Gateway 기능/감사/Attempt 요구가 과한지 검토

3. 설치와 Runtime

항목	기본/환경변수	운영 의미
Server/Data Plane	GWY_SERVER_PORT 8070 / data-plane-port 기본 동일	외부 요청 처리
DB	GWY_DATASOURCE_*	Route/상태/ledger 영속화
TLS	GWY_TLS_ENABLED false	운영 정책에 따라 cert/프로토콜 주입
Health	health/info/metrics/prometheus	probe/관측
Bootstrap mode	FAIL_CLOSED	정책/상태 불명 시 fail closed
Control	GWY_CONTROL_ENABLED false, bind 127.0.0.1	ADM control plane 연동은 명시 활성화

4. 기동 전 Safety 상한

Property	Default	의미
GWY_CONNECT_TIMEOUT_CAP	10s	Route 정책이 넘을 수 없는 connect 상한
GWY_RESPONSE_TIMEOUT_CAP	60s	response timeout 상한
GWY_OVERALL_TIMEOUT_CAP	90s	전체 budget 상한
GWY_RETRY_COUNT_CAP	2	retry 최대
GWY_REQUEST_BODY_BYTES_CAP	10485760	request 10MiB
GWY_RESPONSE_BODY_BYTES_CAP	10485760	response 10MiB
GWY_HEADER_COUNT_CAP	100	Header 수

Property	Default	의미
GWY_HEADER_BYTES_CAP	65536	Header bytes
GWY_RAW_BODY_CAPTURE_ALLOWED	false	원문 body logging 기본 금지
GWY_LOG_SPOOL_BYTES_CAP	2147483648	log spool 2GiB

5. Route·Server Group·Target·Predicate·Rewrite

1. Server Group 에 Target/Member 와 Health 조건을 등록합니다.
2. Route/Binding 에 외부 path/method/predicate 와 대상 Server Group 을 연결합니다.
3. Rewrite/Header/Protocol 정책을 정의하고 허용되지 않은 Host/URL 은 SSRF 정책으로 차단합니다.
4. Connection Test 로 Target 직접 시험과 Gateway 경유 시험을 구분합니다.
5. Validation/version/checksum 을 통과한 변경만 승인/게시 대상으로 올립니다.

구성요소	질문	판정
Route	어떤 요청이 매칭되는가?	path/method/predicate/version
Rewrite	내부 path/header 를 어떻게 바꾸나?	원본 보안 header 오염 금지
Server Group	어디로 보낼까?	health/weight/discovery
Target	실제 Endpoint 가 정상인가?	direct probe + TLS/timeout
Load Balance	어떤 Member 를 선택?	stale/unhealthy 제외, attempt 기록

6. Authentication·Authorization

- 외부 인증과 내부 Service Identity 를 분리합니다.
- Authorization 결과와 Route/Data Scope 를 서버에서 판정하고 Client header 를 신뢰하지 않습니다.
- 관리 Control Plane shared secret 은 data plane credential 과 분리합니다.

7. HMAC·Audience·Body Hash·Nonce·SSRF·TLS

통제	운영 기준
HMAC	서명 대상 canonicalization/version/secret rotation 을 계약으로 고정
Audience	대상 Service/API 가 다르면 token 재사용 차단
Body Hash	서명된 body 와 실제 전달 body 일치
Nonce	single-use + TTL; control default retention 180s
Clock skew	control default allowed skew 60s
SSRF	허용 Target/Host/Protocol 검증; 임의 URL 전달 금지
TLS	Ingress/Target/control plane TLS 정책과 cert 만료/hostname 검증

8. Timeout·Retry·Circuit Breaker·Bulkhead·Rate Limit

상황	행동
connect 실패	retry eligibility/attempt 기록 후 상한 내 재시도
response timeout	부작용 가능 Command 면 UNKNOWN_RESULT 가능; 무조건 retry 금지
5xx	정책과 idempotency 에 따라 retry
circuit open	빠른 실패 + health/incident
bulkhead 포화	queue/thread/connection 상한 초과를 별도 오류로 표시
rate limit counter 장애	설정된 fail-closed/distributed requirement 적용

9. Idempotency·Attempt Ledger·UNKNOWN_RESULT

- Gateway retry/Target 변경은 모두 attempt 로 남겨 동일 업무 요청의 계보를 보존합니다.
- 응답이 없더라도 Target 이 Commit 했을 수 있으므로 idempotency/request hash/provider tracking 을 사용해 결과를 대사합니다.

- GET/안전 조회와 부작용 Command 의 retry 정책을 구분합니다.

10. Validation·Version·Checksum·Approval·Publish

1. Draft 변경을 validation 한다.
2. Route/Group/Policy version 과 checksum 을 만든다.
3. 위험 변경은 Reason/Approval 을 거친다.
4. 승인된 Version 을 게시한다.
5. 각 Gateway Instance 의 적용 ACK/NACK 를 수집한다.
6. 전체/부분 적용 상태를 판정한다.

11. ACK/NACK·Partial Apply

상태	의미	행동
ACK all	모든 대상이 같은 version/checksum 적용	관측 후 완료
NACK	Instance 가 validation/apply 거부	원인 수정 또는 LKG rollback
PARTIAL	일부 ACK/일부 NACK	전체 성공으로 표시 금지; routing safety 판단 후 reconcile
NO RESPONSE	Instance 상태 불명	stale/unknown 처리 후 probe/reconcile

12. LKG·Rollback·Reconciliation

1. Last Known Good version/checksum 을 확인한다.
2. 부분 적용이면 신규 traffic 이 어떤 Version 에 도달할 수 있는지 확인한다.
3. 안전하지 않으면 LKG rollback 요청을 승인한다.
4. Instance 별 ACK/NACK 를 다시 수집한다.
5. Route Registry 와 Runtime snapshot drift 를 대사한다.
6. 정상화 기준을 동일 version/checksum + health + probe 로 판정한다.

13. ADM 운영 Route

ADM Route	역할
/gateway-dashboard	Gateway 대시보드
/gateway-servers	Gateway 연동 서버
/gateway-groups	Gateway 서버 그룹
/gateway-routes	Gateway 경로·라우팅
/gateway-security	Gateway 보안·제한
/gateway-health	Gateway Health·연결시험
/gateway-transactions	Gateway 거래 조회
/gateway-log-policies	Gateway 로그 정책
/gateway-apply-status	Gateway 적용 상태·이력

14. Scale-out·Drift·Health·Probe

- 새 Instance 는 승인된 current/LKG snapshot 을 받아야 traffic 대상이 됩니다.
- route-refresh 30s, policy-refresh 15s, probe 30s, stale-after 90s 기본값을 운영 요구에 맞게 검토합니다.
- Config/Route drift 는 Instance 별 version/checksum 과 Registry 정보를 비교합니다.

15. 장애 Runbook / EDU 적용

장애	확인	복구
Target down	gateway-health + Server Group	unhealthy 제외/failover

장애	확인	복구
Route 오배포	apply-status/version/checksum	LKG rollback
Control auth 실패	HMAC/nonce/skew/TLS	credential/clock/cert 교정; replay 금지
Timeout 급증	attempt/target/CB/metric	원인별 cap/target/CB 조정, Command retry 주의
Partial Apply	Instance ACK/NACK	reconcile 또는 LKG
Log spool 증가	disk/terminal loss metric	disk/permission 복구 후 replay; 원문 body capture 금지

관련 정보 문서

ADM Gateway 화면 → [04_ADM 운영자매뉴얼.pdf](#) / Gateway 운영 Route

플랫폼 설치/Secret/관측 → [05_플랫폼운영매뉴얼.pdf](#) / 설치/Config/관측

외부 호출 개발 → [01_개발자매뉴얼.pdf](#) / 외부연계

Source Trace / 구현 근거

구분	실제 경로·계약	완료 기준
Gateway config	cpf-gateway/src/main/resources/application.yml	Data/Control Plane Config, DB, TLS, Safety cap 계약 일치
ADM Gateway Routes	cpf-admin/frontend/src/app/routes.ts	ADM Gateway Route 와 Runtime operation/version/checksum 일치
Gateway Browser/Fault E2E	실 Runtime	Route/TLS/HMAC/Nonce/Timeout/Partial/LKG/Drift Browser·Fault 시나리오 통과

16. Gateway Route Definition Checklist

축	필수 결정	오류 시
Match	host/path/method/predicate	ambiguous/overlap 거부 또는 우선순위
Rewrite	path/header 변환	보안 header overwrite 차단
Target	server group/member/discovery	unhealthy/stale 제외
TLS	ingress/egress/cert/hostname	fail closed
Auth	token/service identity/audience	401/403
HMAC	canonical input/body hash	signature reject
Nonce	TTL/single use	replay reject
Timeout	connect/response/overall	설치 cap 초과 거부
Retry	count/backoff/eligible error	비역등 blind retry 금지
Rate limit	key/counter/fail mode	counter failure policy
Log	mask/raw body policy	PII/secret capture 금지
Version	route version/checksum	stale apply 차단

17. Connection Test 단계

1. DNS/Target 주소가 승인된 범위인지 검증합니다.
2. Target 직접 TCP/TLS/HTTP 연결을 시험합니다.
3. 인증/Service Identity/Audience 를 시험합니다.
4. Gateway Route match/rewrite 를 통과한 경우 시험을 수행합니다.
5. timeout/body/header cap 을 검증합니다.

- 성공/실패 결과를 operation ID 와 instance 에 연결합니다.
- 취소/만료/재검증 상태를 구분합니다.

18. Publish / ACK / LKG 사례

사례	상태	운영 행동
3 개 Instance 모두 ACK v12	consistent	v12 current
2 ACK / 1 NACK	PARTIAL	NACK instance traffic 격리 또는 LKG rollback
1 ACK / 2 no response	UNKNOWN/PARTIAL	stale 판단 전 probe, 신규 변경 중지
v12 장애물 상승	runtime regression	승인 후 v11 LKG rollback
rollback 도 일부 NACK	recovery partial	traffic safety 확보 + instance 별 reconcile

19. Attempt Ledger 해석

필드	의미	운영 질문
transactionId	업무 root	같은 거래의 모든 gateway/target attempt 인가?
routeVersion	사용 Route	어떤 정책으로 보냈나?
attempt	호출 회차	retry/failover 몇 번째?
targetId	선택 Endpoint	어디로 보냈나?
started/ended	latency	timeout budget 어디서 소진?
result	success/failure/unknown	부작용 결과 확정 가능한가?
providerTracking	상대 조회 키	reconcile 가능?

20. Gateway 보안 Negative Test

공격/오류	기대
HMAC tamper	401/403, 상세 secret 미노출
nonce replay	재사용 거부
clock skew 초과	거부
audience mismatch	거부
SSRF private/meta endpoint	route validation/target policy 로 거부
oversize body/header	cap 초과 거부
raw body capture request	기본 false 유지
path rewrite traversal	정규화/허용 정책으로 거부
untrusted control request	shared secret/TLS/nonce 검증

21. Scale-out / Drift / Reconcile 상세

- 새 Instance 는 current approved snapshot 을 로드하고 checksum 을 보고합니다.
- Health probe 가 정상이고 stale-after 안쪽인지 확인합니다.
- Registry current version 과 instance applied version 을 비교합니다.
- drift instance 에는 traffic 을 제한하거나 reconcile command 를 보냅니다.
- reconcile 결과 ACK/NACK 를 수집합니다.
- LKG 와 current 모두 불일치하면 수동 장애 절차로 전환합니다.

22. 신규 Gateway 설치 순서

- Gateway 가 필요한 외부 trust boundary 와 공개 API 목록을 확정합니다.
- Artifact/checksum 과 DB schema, Service Account, TLS certificate/Secret 을 준비합니다.
- GWY_DATASOURCE_*, GWY_SERVER_PORT, TLS, Safety Cap 을 설정합니다.

- 초기에는 control plane 을 닫은 상태로 data plane health 와 DB 연결을 확인합니다.
- Server Group/Target 을 등록하고 직접 Connection Test 를 수행합니다.
- Route/Binding 을 Draft 로 만들고 predicate/rewrite/auth/timeout 을 validation 합니다.
- 관리 Control Plane 연동이 필요하면 loopback/TLS/shared secret/nonce 정책을 구성합니다.
- 승인→Publish→Instance ACK/NACK→Probe 를 확인한 뒤 traffic 을 개방합니다.
- LKG version/checksum 과 rollback 명령/승인자를 인계합니다.

23. Route 설계 예 - 외부 /partner/payments → 내부 payment-service

요소	예시 의미	검증
Ingress	HTTPS POST /partner/payments	TLS/method/body cap
Predicate	partner host + path + method	다른 host/path 비매칭
Auth	외부 token/HMAC + audience	tamper/replay test
Rewrite	/partner/payments → /api/payments	허용 header 만 전달
Target Group	payment-service	healthy member only
Timeout	connect/response/overall	설치 cap 이하
Retry	비먹등 Command	idempotency/UNKNOWN 없이는 blind retry 금지
Attempt	transactionId/attempt/target	response loss reconcile
Log	masked metadata	raw body false
Publish	version/checksum/approval	ACK all 또는 partial 처리

위 값은 설명을 위한 의미 예이며 실제 Route ID/Path/Target 은 고객 설정이 정본입니다. Framework 의 실제 기본 상한과 상태 의미는 이 문서 §4~§12 를 따릅니다.

24. Control Plane HMAC 검증 흐름

- 요청 시각과 nonce 를 생성합니다.
- method/path/body hash/audience/version 을 canonical input 으로 만듭니다.
- shared secret/rotation version 으로 서명합니다.
- Gateway 는 TLS/allowed skew(기본 60s)/nonce single-use/retention(기본 180s)/audience/body hash 를 검증합니다.
- 검증 실패 요청은 적용하지 않고 원문 secret/body 를 로그에 남기지 않습니다.
- 성공 요청도 version/checksum/approval 조건을 통과해야 실제 변경합니다.

25. Route 변경 Rollback 의사결정

관측	결정
Publish validation 실패	게시 전 수정, current 유지
1 개 NACK, traffic 미수용	해당 instance 격리 후 원인 수정/reconcile
일부 ACK 가 이미 traffic 수용	PARTIAL incident, 신규 게시 중지
새 version 으로 오류율 증가	LKG rollback 검토
DB/Control 장애로 적용 상태 불명	UNKNOWN, instance snapshot/probe 조회
LKG rollback 도 partial	traffic safety 우선 + instance 별 reconcile

26. Gateway 운영 지표/Alert

지표	의미	Alert 질문
request count/error rate	전체 traffic/실패	route/target/client 어느 측?
latency p95/p99	timeout budget	connect/target/rewrite 어디?
retry/attempt count	resilience	retry storm?
circuit state	dependency health	open 지속?
rate-limit reject	client/정책	정상 보호인가 오설정인가

지표	의미	Alert 질문
target health/stale	load balance	member 제거 필요?
apply ACK/NACK	config consistency	partial apply?
route version drift	instance consistency	reconcile 필요?
log spool usage	disk/log delivery	terminal loss 위험?

27. Gateway 장애 복구 Drill

Drill	기대 결과
Target 1 개 종료	health 제외 + 다른 member 로 routing
응답 지연	timeout/circuit/attempt 기록
Publish 1 instance NACK	PARTIAL + LKG/reconcile
Control nonce replay	거부
Cert 만료	TLS fail closed + rotation runbook
DB 단절	새 변경 fail closed, current data plane 정책의 허용 범위 확인
log disk full	bounded spool/alert/복구 후 replay

28. Gateway 질문을 바로 정본으로 보내는 운영 인덱스

질문	먼저 볼 절	판단
언제 Gateway 를 켜야 하나	§2 선택 기준	외부 trust boundary/공통 route 정책 필요 여부
무엇을 설치하나	§3~§4	Data Plane/DB/TLS/Control/Safety cap
Route 는 어떻게 만든다	§5, §16, §23	predicate/rewrite/target/version/checksum
인증/HMAC/Nonce 는	§6~§7, §24	trust source/canonical input/skew/replay
timeout/retry 는	§8	retry eligibility 와 idempotency/unknown
게시가 일부 실패했다	§10~§12, §18	ACK/NACK/PARTIAL/LKG/reconcile
Target 이 죽었다	§17, §21, §27	connection test/health/member routing
어디서 운영하나	§13 + 04 Gateway Route	ADM gateway-* 화면

29. 변경 승인 전 최종 Gate

Gate	통과 조건
Validation	route/predicate/rewrite/target/security schema 유효
Security	TLS/auth/HMAC/audience/body hash/nonce/SSRF 조건 충족
Resilience	timeout/retry/circuit/bulkhead/rate-limit 정책 명시
Identity	transaction/idempotency/attempt/provider tracking 연결
Version	route version/checksum 및 승인 대상 snapshot 고정
Publish	대상 instance 와 expected ACK 집합 확정
Recovery	NACK/timeout/PARTIAL 때 LKG/reconcile/rollback 절차 존재
Evidence	reason/approval/audit/change/connection test 결과 연결

30. Gateway 도입·운영 완료 판정 Gate

영역	완료 조건
설치	DB/Port/TLS/Control Secret/Health/Fail-closed 설정이 확정
Route	Predicate/Rewrite/Server Group/Target/Discovery/Load Balance 가 validation 과 connection test 를 통과

영역	완료 조건
보안	AuthN/AuthZ/HMAC/Audience/Body Hash/Nonce/SSRF/TLS negative test 를 통과
Resilience	timeout budget/retry/circuit/bulkhead/rate limit 이 설치 상한 안에서 동작하고 Command UNKNOWN 을 구분
Publish	version/checksum/approval 후 모든 Instance ACK, NACK/PARTIAL 은 Reconcile 또는 LKG 로 수렴
Scale-out	신규 Instance 가 승인 snapshot 을 받은 뒤 traffic 에 참여하고 drift 0
복구/인수	Target down/route 오배포/control auth/partial/log spool 장애 Runbook 과 rollback Evidence 인계

31. Gateway 인수 Evidence Record

영역	Evidence
Install	DB/port/TLS/control secret/fail-closed/health configuration
Route	route/server group/target/predicate/rewrite/version/checksum + connection test
Security	auth/HMAC/audience/body hash/nonce/SSRF/TLS negative result
Resilience	timeout budget/retry/circuit/bulkhead/rate limit/unknown result
Publish	approval + instance ACK/NACK/PARTIAL + LKG/reconcile result
Scale-out	new instance snapshot/version/checksum/health + drift 0
Recovery	target down/route rollback/control auth/log spool drill + audit reference